

EST. 2025

SECURE DEV LABS

SOFTWARE AGENCY

Crafting Secure Digital Experiences

Ethical Hacking Internship

Week 2 - Web Application Mapping and Input Discovery

Class Focus:

- Train interns to understand the structure of a web application before testing vulnerabilities.

Topics Covered:

- Request and response basics
- Parameters, forms, and inputs
- Cookies and sessions
- Intercepting traffic with Burp Suite
- Mapping endpoints and user-controlled inputs
- Identifying attack surface

Weekly Task:

- **owasp juice-shop/DVWA:** You are only required to install one Vulnerable Machine.
 - **Installation for DVWA:** You do not need to install the DVWA separately because it is already in the Metasploitable 2 Machine & we already learnt how to install the Metasploitable 2 Machine? - Provide the Screenshot.
 - **Installation for owaspjuiceshop:** You can clone the repository from the given link <https://github.com/juice-shop/juice-shop> - After Installation & setup provide the Screenshot.
 - **Practical:**
 - On the Web find out all of the available input fields - provide a screenshot.
 - Map all those endpoints that are basically user controlled.

- **Burpsuite:** Burpsuite is already installed in your Kali Machine.
 - **Practical:**
 - Capture your first request by using Burpsuite - Provide Screenshot.
 - Forward that captured request to the intercept - Provide Screenshot.
 - Forward that captured request to the repeater - Provide Screenshot.
 - **Theory:**
 - What is Burpsuite ? How it is different from nmap defined in your own words.
 - By using draw.io create a perfect visualization of Burpsuite as an interceptor between Client & the Server - Provide the Screenshot

- **Request & Response:**
 - **Practical:**
 - From your browser make a request to any web (ex google.com, facebook.com) - Provide Screenshot
 - What response did you get from your request ? - Provide Screenshot.
 - **Theory:**
 - By using draw.io create the perfect diagram that shows how a browser sends a request to the server & how a Server responds to the request (a basic visualization) - Provide Screenshot
 - Define in your own words what is Request & Response in the context of Web Application?
 - How would you compare the Sender as a Request & Receiver/Feedback as a Response?
 - What are the common Response codes of HTTP ?

- **Cookies, Sessions, Authentication & Authorization:**

- **Practical:**

- **Log in to the vulnerable web application**
 - Capture the HTTP request during login
 - Provide a screenshot of the captured request
- **Capture the credentials in the response**
 - Identify where the credentials appear in the server response
 - Provide a screenshot of the response
- **Browse to a directory within the web application**
 - Capture the HTTP request for accessing that directory
 - Provide a screenshot of the captured request

- **Theory:**

- What do you think about Cookie & Session ? Are they important for modern Web Architectures ?
- Using draw.io create a diagram that illustrates how a cookie is initially assigned to a user by the server, and how the browser automatically sends that cookie back to the server with each subsequent request - Provide Screenshot.
- Define **Authentication (AUTHN)**
- Define **Authorization (AUTHZ)**
- Write one difference between AUTHN and AUTHZ
- Explain why cookies/sessions are used

- **DNS (Domain Name System):**

- **Practical:**

- Open your browser and visit a website (e.g., Google or Facebook)
 - Use browser DevTools or a tool (like **nslookup** or **ping**) to observe the DNS lookup
 - Capture:
 - The **domain name** (e.g., google.com)
 - The **IP address returned**
 - Provide:
 - Screenshot of the DNS request/result
 - Check what IP address the domain resolves to
 - Identify:
 - IPv4 or IPv6 address
 - Any multiple IPs (if shown)
 - Provide:
 - Screenshot of the DNS response

- **Theory:**

- Define **DNS** in your own words
 - Explain what a **DNS request** is
 - Explain what a **DNS response** is
 - Compare:
 - Domain name (human-readable)
 - IP address (machine-readable)
 - Why is DNS important for the internet?
 - Create a simple diagram using draw.io showing:
 - User enters domain (e.g., google.com)
 - Browser sends DNS request
 - DNS server resolves domain
 - DNS server returns IP address
 - Browser connects to server using IP
 - Provide:
 - Screenshot of your diagram